RAPPORT — Mise en production du portail de suivi (srv-core)

Les sorties complètes sont dans le dossier preuves/. Le tableau ci-dessous donne, pour chaque exigence, la commande de preuve et la partie utile de sa sortie.

1. Tableau de conformité

Exigence	Commande de preuve	Partie utile de la sortie
E1.1 Groupe et compte lea	`id lea` ; `getent passwd lea`	`uid=5104(lea) gid=5003(suivi) groupes=5003(suivi)` ; `lea:x:5104:5003:Lea Fabre - responsable suivi des tournees:/home/lea:/bin/bash`
E1.2 Expiration du mot de passe	`chage -l lea`	minimum 1, maximum 90, avertissement 14, inactivité 7 jours après expiration (expire le 3 févr. 2027, inactif le 10 févr. 2027)
E1.3 Ni wheel ni ssh-admins	`id -nG lea` ; `id -nG lea | grep -Ewc 'wheel|ssh-admins'`	groupes : `suivi` ; le compte renvoie `0`
E1.4 Compte de service	`getent passwd helios-suivi` ; `id -u helios-suivi` ; `ls /home`	`helios-suivi:x:982:979:…:/srv/helios/suivi:/sbin/nologin` ; uid `982` ; pas de dossier helios-suivi dans /home
E2.1 www en root:suivi 2770	`ls -ld /srv/helios/suivi/www`	`drwxrws---+ 2 root suivi`
E2.2 helios-suivi lit et écrit dans www	`getfacl -p /srv/helios/suivi/www`	`user:helios-suivi:rwx` ; `default:user:helios-suivi:r--` ; `default:other::---`
E2.3 zabbix : stat oui, ls non	`runuser -u zabbix -- stat / ls / cat …`	`stat` rc=0 ; `ls` : Permission non accordée (rc=2) ; `cat` : Permission non accordée (rc=1)
E2.4 Fichier créé par un membre de suivi, quel que soit l'umask	`su - lea -c "umask $m; touch …"` pour 022, 077 et 000	les trois fichiers : `-rw-rw----+ lea suivi`
E2.5 index.html déposé par lea	`ls -l …/index.html` ; `getfacl -p …/index.html`	`-rw-rw----+ lea suivi` ; `user:helios-suivi:r--`, `group::rwx #effective:rw-`, `other::---` ; nadia : Permission non accordée
E3 Script de publication	`runuser -u helios-suivi -- helios-suivi-publish.sh` ; `python3 -m json.tool` ; `journalctl -t helios-suivi-publish`	rc 0 et JSON valide (genere, hote, derniere_mesure, charge_1min, mem_dispo_ko, mesures) ; rc 2 « une autre instance tourne deja » ; rc 3 « repertoire non inscriptible » (lancé en nadia) ; rc 1 « ligne de telemetrie invalide »
E4.1 Portail sous helios-suivi, rattaché à helios.target, redémarrage auto	`systemctl is-active` / `is-enabled` ; `systemctl list-dependencies helios.target` ; `kill -9`	`active` / `enabled` ; helios-suivi.service sous helios.target ; PID 11192 → 11908, `active`, HTTP 200 après 4 s
E4.2 Ressources	`systemctl show -p MemoryMax -p CPUQuotaPerSecUSec helios-suivi.service`	`MemoryMax=134217728` ; `CPUQuotaPerSecUSec=500ms`
E4.3 Durcissement	`systemd-analyze security helios-suivi.service` ; `curl`	`Overall exposure level … 1.3 OK` ; `/` → 200 et `/etat.json` → 200
E4.4 Publication planifiée	`systemctl list-timers helios-suivi-publish.timer` ; `curl …/etat.json` à 2 min d'écart	timer actif ; `genere` : 12:56:04 puis 12:58:04
E4.5 Aucune unit des TP précédents modifiée	—	seuls des fichiers ont été ajoutés ; `enable` a créé le lien dans helios.target.wants/

Exigence	Commande de preuve	Partie utile de la sortie
E5 Délégation sudo	`visudo -c` ; `sudo -l -U lea` ; `sudo -l -U lea /usr/bin/systemctl restart sshd` ; essai réel en lea	fichier `-r--r-----. root root` (0440), analyse réussie ; 5 commandes exactes listées ; `restart sshd` et `journalctl --vacuum-time=1s` : rien n'est listé ; en session lea, les commandes autorisées passent et les deux refusées sont refusées
E6.1 / E6.2 Port 8080 uniquement dans internal, zone drop	`firewall-cmd --zone=internal --query-port=8080/tcp` (runtime et --permanent) ; `--get-default-zone` ; `--list-all-zones` ; `nft list ruleset | grep 8080`	`yes` et `yes` ; `drop` ; 8080 n'apparaît que dans la ligne de internal (`ports: 10051/tcp 2242/tcp 8080/tcp`) ; `tcp dport 8080 accept`
E6.3 Test depuis srv-edge	`curl http://10.42.0.10:8080/etat.json` ; `nc -zv -w2 192.168.56.10 8080`	`200` ; `No route to host`, rc=1
E7.1 SSH inchangé	`sshd -T | grep -E '^(port|permitrootlogin|passwordauthentication|allowgroups) '`	`port 2242`, `permitrootlogin no`, `passwordauthentication no`, `allowgroups ssh-admins`
E7.2 lea sans accès SSH	`ssh -p 2242 lea@10.42.0.10` (depuis srv-edge) ; `journalctl -u sshd --since "1 hour ago" | grep -i 'user lea'`	`User lea from 10.42.0.11 not allowed because none of user's groups are listed in AllowGroups`
E7.3 Timer et journald	`systemctl is-active helios-watch-auth.timer` ; `ls -d /var/log/journal` ; `grep -rH Storage /etc/systemd/journald.conf.d/`	`active` ; `/var/log/journal` ; `50-helios.conf:Storage=persistent`
E8 Agent et sondes	`systemctl is-active` / `is-enabled zabbix-agent2 sysstat-collect.timer` ; `zabbix_get … agent.ping`, `helios.suivi.http`, `helios.suivi.age`	`active` / `enabled` ; `1` ; `200` ; `6`
E9.1 à E9.4 Sauvegarde	`systemctl start helios-suivi-backup.service` ; `sha256sum -c` ; `tar -tzf` ; 9 exécutions de plus ; `systemctl list-timers helios-suivi-backup.timer`	`suivi-20261105-155908.tar.gz` + `.sha256`, `Réussi` ; contenu : srv/helios/suivi, les 5 units, 92-helios-suivi, la conf Zabbix, les deux scripts ; 7 archives conservées ; rc 2 (verrou) et rc 3 (prérequis) ; prochaine exécution du timer à 03:15:00
E9.5 Restauration	voir section 3	voir section 3
Après redémarrage	`systemctl reboot`, puis `systemctl is-active …` ; `curl` ; `firewall-cmd --query-port` ; `zabbix_get` ; `sshd -T` ; `getenforce`	7 unités et firewalld `active` ; `/etat.json` → 200 ; port 8080 `yes` ; sondes `200` et `17` ; SSH inchangé ; `Enforcing`

2. Justifications

(a) Durcissement de helios-suivi.service. L'unit combine NoNewPrivileges, PrivateTmp, PrivateDevices, ProtectSystem=strict, ProtectHome, ProtectKernel*, ProtectControlGroups, RestrictAddressFamilies, RestrictNamespaces, MemoryDenyWriteExecute, SystemCallFilter=@system-service et un CapabilityBoundingSet vide. Il n'y a volontairement aucun ReadWritePaths : le serveur web n'écrit nulle part, seule l'unit de publication a le droit d'écrire dans www. Score obtenu : 1.3 OK, très en dessous de 4.0. Je n'ai dû retirer ou adapter aucune directive : le service a démarré dès le premier essai et répond 200 sur / et sur /etat.json. Le seul point encore signalé est UMask= (0.1), que je n'ai pas modifié.

(b) Pourquoi --x et pas r-x pour zabbix sur www. zabbix doit seulement faire un stat sur etat.json, dont il connaît le nom. Pour cela, il lui faut le droit de traverser le dossier (x), pas celui de le lister (r). Sans cette entrée, j'ai observé « stat: impossible d'exécuter statx … Permission non accordée » (rc=1) et un échec de la sonde helios.suivi.age. Avec --x, stat réussit (rc=0) alors que ls échoue (rc=2) : l'agent voit le fichier sans pouvoir énumérer le contenu de www. Avec r-x, ls aurait réussi et zabbix aurait vu tout ce que

contient le dossier, ce qui dépasse le besoin.

(c) Le risque d'un joker * derrière journalctl. Une règle « journalctl * » laisserait lea ajouter n'importe quelle option : --vacuum-size ou --vacuum-time pour effacer des journaux (y compris ceux qui prouvent une intrusion), --rotate, ou --file pour lire d'autres journaux. Sans --no-pager, journalctl et systemctl status ouvrent less en root, d'où l'on peut lancer un shell. Ma règle liste des commandes exactes, arguments compris (-u … -n 100 --no-pager) : toute option supplémentaire fait refuser la commande, ce que j'ai vérifié avec --vacuum-time=1s.

3. Test de restauration (E9.5)

Dernière archive utilisée : suivi-20261105-155927.tar.gz.

- (a) Extraction dans un répertoire de test (mktemp -d /root/restore-test.XXXXXX, puis tar --acls -xzpf), et comparaison des ACL de www avec la production par diff <(getfacl -c -p …) <(getfacl -c -p …) : « ACL de www identiques a la production ». Durée de cette série : 3 s.
- (b) Incident simulé. Première tentative : mon rm demandait une confirmation (alias rm -i), le fichier n'a donc pas été supprimé et cette tentative ne prouve rien ; je l'ai refaite. Tentative valable : sauvegarde des ACL d'index.html, rm -f, ls (il ne reste que etat.json), curl (listing du dossier), puis tar --acls -xzpf … -C / srv/helios/suivi/www/index.html et restorecon -v. Résultat : index.html revient en -rw-rw----+ lea suivi, etat.json est inchangé, « ACL de index.html retrouvees », et curl renvoie de nouveau la phrase de lea. Durée : moins d'une seconde (0 s en secondes entières).

4. Mesure sous charge

Boucle de 2000 requêtes curl sur /etat.json (12,087 s), avec sar -u 1 30 en parallèle.

- CPUUsageNSec : 300 744 000 avant, 1 117 134 000 après.
- MemoryCurrent : 10 555 392 avant, 10 559 488 après.
- nr_throttled : 0 avant, 0 après.

Le portail a consommé 0,82 s de CPU en 12 s (environ 6,8 % d'un CPU) pour un quota de 50 %, et nr_throttled est resté à 0 : le quota n'a pas joué. sar montre un CPU saturé (idle à 0 %, environ 62 % user et 37 % system) pendant la boucle, mais ce sont les 2000 processus curl qui le consomment, pas le portail ; la mémoire est restée à environ 10 Mo pour 128 Mo autorisés.

5. Limites connues

- L'instantané 04-debut-projet a été pris après l'installation de l'agent Zabbix (E8.1), pas avant.
- Pour que helios-suivi, zabbix et lea puissent traverser les dossiers parents, j'ai ajouté des ACL sur /srv/helios/suivi et sur /srv/helios (dossier du TP2), sans toucher à leurs droits de base.
- Pendant le projet, la variable $P s'est vidée après une session su - lea : certaines sorties (charge, E6, E7, E7-lea, E9, sar-charge) ont été écrites à la racine / par erreur, puis déplacées dans preuves/ sans aucune modification.
- Le nom d'hôte de la VM est localhost.localdomain, ce qui apparaît dans le champ hote d'etat.json.
- Le portail est en HTTP en clair (imposé par la fiche) ; la sauvegarde est sur le même disque que le service, sans copie hors machine ; l'unit de sauvegarde n'est pas durcie.
- La VM n'a qu'un seul CPU, ce qui limite la portée de la mesure sous charge.